UNIT 5 · TOPIC 5.2

Protecting Applications and Data: Managerial Controls and Access Controls

Quiz, Answer Key

Teacher answer key, 18 questions, 1 point each. The correct answer is highlighted; the explanation and distractor notes follow.

1. Which of the following is an example of a managerial control related to application and data security?

- ○ A. Installing a firewall to filter incoming network traffic
- **● B. Enforcing a data classification policy that labels R&D documents as Confidential**
- ○ C. Configuring file permissions using chmod on a Linux server
- ○ D. Deploying antivirus software to detect and quarantine malware

Correct answer: B

Why: Data classification policies are administrative (managerial) controls, they govern how data must be handled and protected through rules and procedures rather than technology. Firewalls, file permissions, and antivirus software are all technical controls enforced by hardware or software.

*Why the others are wrong: **A**, A firewall is a technical control that enforces access rules at the network layer automatically, not a managerial control. **C**, chmod implements permissions at the OS level; it is a technical control, not a policy document. **D**, Antivirus software is a technical control, it operates automatically without human procedural involvement.*

2. Which term correctly describes data that is stored on a server's hard drive and is not currently being transmitted or actively processed?

- ○ A. Data in transit
- ○ B. Data in use
- ○ C. Data in motion
- **● D. Data at rest**

Correct answer: D

Why: Data at rest refers to data stored on a medium, such as a hard drive, database, or backup tape, that is not actively moving over a network or being processed. The state of data determines which protective controls apply: encryption at rest, TLS in transit, memory protection in use.

*Why the others are wrong: **A**, Data in transit is data actively moving across a network connection between systems. **B**, Data in use is data currently loaded into memory and being processed by an application or CPU. **C**, Data in motion is a synonym for data in transit, data traveling over a network, not data stored on disk.*

3. An organization requires all developers to complete mandatory security-awareness training before being granted access to production systems. This requirement is best classified as which type of control?

- ○ A. Technical
- ○ B. Physical
- **● C. Managerial**
- ○ D. Compensating

Correct answer: C

Why: Mandatory training is an administrative (managerial) control. It shapes behavior through policy and education rather than through hardware, software, or physical barriers. Managerial controls are preventive in nature but rely on human compliance to be effective.

*Why the others are wrong: **A**, Technical controls are enforced automatically by software or hardware systems, a login screen, a firewall, or an IDS. Training requires human action to have effect. **B**, Physical controls restrict access to facilities or equipment using locks, badges, or*

cameras, not relevant here. ***D****, Compensating controls are alternative controls substituted when a primary control cannot be implemented. A training requirement is a primary planned control, not a substitute.*

4. A healthcare company classifies patient records as "Restricted" and internal memos as "Internal Use Only." How should the Restricted classification affect the security controls applied to patient records compared to internal memos?

○ A. Restricted data requires fewer controls because its label already alerts staff, reducing accidental exposure risk.

○ B. Data classification affects only physical security controls, not digital access or encryption requirements.

○ C. Both classifications should receive identical controls to ensure consistent and simplified policy enforcement.

● D. Restricted data should receive the strongest protections available, including encryption, strict need-to-know access, and comprehensive audit logging.

Correct answer: D

Why: The purpose of data classification is to match the intensity of security controls to the potential harm of a breach. Restricted data carries the highest sensitivity and requires the strongest protections, encryption at rest and in transit, strict access controls enforcing need-to-know, and full audit trails, because a breach would cause the greatest damage.

Why the others are wrong: ***A****, A classification label is documentation, not a control. The label itself provides no protection and does not reduce the attack surface.* ***B****, Data classification drives both physical and digital security requirements; encryption, access control, and network segmentation are all directly influenced by classification level.* ***C****, Applying identical controls across all tiers either over-spends resources on low-sensitivity data or under-protects high-sensitivity data, neither is acceptable practice.*

5. Vitahealth Solutions needs to restrict the /RandD/Formula directory so that only the head researcher can write to it. Access decisions must be based on defined job roles rather than individual user identities. Which access control model best fits this requirement?

● A. Role-Based Access Control (RBAC)

○ B. Mandatory Access Control (MAC)

○ C. Discretionary Access Control (DAC)

○ D. Attribute-Based Access Control (ABAC)

Correct answer: A

Why: RBAC assigns permissions to roles, "Head Researcher," "R&D Member", rather than to individual user accounts. This maps directly to the requirement: permissions follow the job role, so onboarding and offboarding automatically adjust access without per-user reconfiguration. DAC relies on resource owners; MAC uses classification labels set by a central authority; ABAC is more expressive but more complex than this use case requires.

Why the others are wrong: ***B****, MAC enforces access through centrally assigned classification labels and security clearances, designed for government/military systems, not typical job-role scenarios.* ***C****, DAC gives control to the resource owner, who can grant or revoke permissions arbitrarily. This makes systematic role-based enforcement difficult and error-prone.* ***D****, ABAC could implement role-based decisions using role attributes, but it is significantly more complex than RBAC and is not the canonical model when job roles are the sole access criterion.*

6. During a code review, a developer notices that the application transmits patient records to a remote server without any encryption. Which data state is most at risk in this scenario, and which control most directly mitigates the vulnerability?

● A. Data in transit; TLS/SSL encryption of the communication channel between client and server

○ B. Data in use; Address Space Layout Randomization (ASLR) to protect in-memory processing

○ C. Data at rest; full-disk encryption applied to the server's storage volume

○ D. Data at rest; access control lists (ACLs) restricting who can open the patient records files

Correct answer: A

Why: Unencrypted transmission exposes data in transit, data actively traveling over a network. TLS/SSL encrypts the channel end-to-end, ensuring that even if a packet is intercepted, the contents cannot be read. The other answers address different data states or unrelated threat vectors.

*Why the others are wrong: **B**, ASLR is a memory protection technique that randomizes address layouts to mitigate buffer-overflow exploits. It protects data in use from memory attacks, not network transmission. **C**, Full-disk encryption protects data at rest on storage media. It does not affect data security once the data leaves the server and travels over the network. **D**, ACLs control who can access a file on a system but have no effect on how that data is protected once it is being transmitted over a network connection.*

7. A defense contractor manages classified project documents that must be accessible only to personnel with the required government clearance level, regardless of who created or owns the documents. The security team is evaluating DAC, RBAC, and MAC. Which model is most appropriate, and what is the strongest justification for that choice?

○ A. DAC, it gives document owners flexible control, allowing project teams to manage their own permissions without bottlenecks.

● B. MAC, access is determined by centrally enforced classification labels and clearance levels that cannot be overridden by resource owners.

○ C. RBAC, it maps access to job roles, ensuring that clearance levels are enforced at an organizational level through role assignments.

○ D. ABAC, it can combine multiple attributes including clearance level, project code, and time-of-day to grant access with maximum precision.

Correct answer: B

Why: MAC is explicitly designed for environments where a central authority, not individual owners, must control access based on security labels and subject clearances. The no-read-up / no-write-down properties (Bell-LaPadula model) ensure a Confidential-cleared user cannot access Secret documents, regardless of who created them. DAC allows owners to misconfigure access; RBAC handles roles but doesn't enforce mandatory clearance-level constraints; ABAC is technically capable but over-engineered when MAC is the purpose-built standard for this use case.

*Why the others are wrong: **A**, DAC is the weakest model for classified environments: a document owner could intentionally or accidentally grant access to someone without sufficient clearance, creating a policy violation. **C**, RBAC can approximate clearance enforcement through role design, but it lacks mandatory constraints, a misconfigured role assignment could leak access across clearance boundaries without systemic prevention. **D**, ABAC is expressive and can model the same rules, but for a use case that exactly matches MAC's purpose (clearance + classification), MAC is the canonical, standardized answer and simpler to audit for compliance.*

8. A CISO reviews a data classification policy and finds that Public, Internal, and Confidential data all receive the same encryption standards and audit logging requirements. What is the primary security risk of this approach, and what corrective action is recommended?

○ A. There is no significant risk, uniform controls simplify compliance and reduce the chance of configuration errors across tiers.

● B. Confidential data is under-protected because controls are calibrated to the lowest tier; the recommended fix is tiered controls scaled to classification level and breach impact.

○ C. Public data is over-protected, wasting IT resources; the fix is to remove controls from Public data while keeping them on Confidential data.

○ D. The classification framework should be abandoned entirely; uniform encryption of all data is sufficient without tiered labels.

Correct answer: B

Why: When controls are applied uniformly across classification tiers, they are typically calibrated to a level acceptable for the lowest-sensitivity tier. This leaves Confidential data with insufficient protection relative to the impact a breach would cause. NIST guidelines and risk-based security frameworks require that control intensity, encryption strength, access restrictions, logging frequency, retention, scale with data sensitivity. The fix is tiered controls: lighter for Public, moderate for Internal, strongest for Confidential.

*Why the others are wrong: **A**, Uniform controls do simplify management, but simplicity is not the goal of security, adequacy of protection is. Simplification that leaves high-value data under-protected is a net negative. **C**, Over-protecting Public data wastes resources but is a secondary concern. The more critical risk is under-protecting Confidential data, which carries far higher breach consequences. **D**, Encryption alone does not substitute for access controls, audit logging, data-handling procedures, or breach notification plans. Classification frameworks exist precisely because different data requires different response obligations.*

9. Vitahealth Solutions' security team proposes four managerial controls: (1) a data classification policy, (2) acceptable use agreements signed by all staff, (3) mandatory quarterly security training, and (4) a documented incident response plan. A security auditor argues that these controls are insufficient on their own. Which evaluation of the auditor's position is most accurate?

○ A. The auditor is incorrect, well-designed managerial controls are sufficient; adding technical controls introduces unnecessary operational complexity.

○ B. The auditor is partially correct, managerial controls only serve regulatory compliance purposes, and technical controls are responsible for all actual security enforcement.

● C. The auditor is correct, managerial controls establish policy intent but require human compliance; without technical enforcement mechanisms, a determined insider or external attacker can bypass them.

○ D. The auditor is incorrect, managerial controls primarily serve to limit legal liability, which is the principal goal of an organizational security program.

Correct answer: C

Why: Managerial controls set the framework, rules, and expectations, but they cannot enforce themselves. An employee who ignores the acceptable use agreement faces no automatic technical barrier. Defense-in-depth requires layering: managerial controls (policy, training, classification) define what must be done, while technical controls (file permissions, encryption, access logging) enforce it automatically. Failure in the human layer is caught by the technical layer and vice versa.

*Why the others are wrong: **A**, Relying solely on managerial controls assumes perfect human compliance, which is a well-documented failure point in security programs. No automated enforcement means a single non-compliant employee can cause a breach. **B**, Managerial controls serve both regulatory compliance and genuine operational security, they are not purely cosmetic. However, they do need to be paired with technical controls to be effective, so the auditor's concern is valid. **D**, Legal liability is one benefit of a documented security program, but the primary objective of security controls is to protect assets and maintain confidentiality, integrity, and availability of data.*

10. Which Linux command is used to change the access permissions of a file or directory?

○ A. chown

○ B. chgrp

● C. chmod

○ D. ls -l

Correct answer: C

Why: chmod (change mode) modifies the read, write, and execute permission bits on files and directories. It is the primary command for configuring access control on a Linux file system. The others either change ownership metadata or only display permissions.

*Why the others are wrong: **A**, chown changes the owner of a file, who the file belongs to, not the permission bits controlling what actions are allowed. **B**, chgrp changes the group associated with a file, not the read/write/execute permissions. **D**, ls -l lists files in long format, displaying current permissions, but it does not modify them.*

11. A Linux file has the permission string rwxr-x---. What level of access does a user who belongs to the file's group have?

● A. Read and execute only

○ B. Read, write, and execute

○ C. Read only

○ D. No access

Correct answer: A

Why: The permission string rwxr-x--- is divided into three three-character segments: owner (rwx), group (r-x), and others (---). The group segment r-x means read (r) and execute (x) are set, but write (-) is not. Group members can read and execute the file but cannot modify it.

*Why the others are wrong: **B**, rwx, read, write, and execute, describes the owner's permissions (the first three characters), not the group's. **C**, Read-only would be represented as r-- for the group. The hyphen in the middle of r-x indicates no write, but the x confirms execute access is granted alongside read. **D**, No access (---) is what "others", users who are neither the owner nor in the file's group, have in this permission string.*

12. Which of the following is a technical control that directly enforces a data access restriction on a Linux system?

● A. Using chmod to restrict file access to authorized users only

○ B. Conducting annual employee security awareness training

○ C. Publishing a data classification policy document

○ D. Writing and distributing an incident response plan

Correct answer: A

Why: Configuring permissions with chmod is a technical control, it enforces access restrictions automatically at the operating system level, independent of whether users are aware of or comply with policy. The other three options are managerial (administrative) controls: they create rules, awareness, or procedures but rely on human compliance to have effect.

*Why the others are wrong: **B**, Training improves user knowledge and behavior but creates no technical access barrier. **C**, A policy document defines expected behavior but provides no automated enforcement, an employee can ignore it without any system-level barrier. **D**, An incident response plan is a procedural control that governs actions after a security event occurs, it does not restrict access before or during an event.*

13. A security administrator needs to set permissions on /RandD/Research so that the R&D group has full access (read, write, and execute) and all other users have no access. Which chmod command correctly implements this?

● A. chmod 770 /RandD/Research

○ B. chmod 750 /RandD/Research

○ C. chmod 700 /RandD/Research

○ D. chmod 755 /RandD/Research

Correct answer: A

Why: In octal notation, each digit maps to owner, group, and others respectively. Full access = 7 (rwx = 4+2+1). No access = 0 (---). The requirement, owner full, group full, others none, translates to 770. chmod 770 /RandD/Research is the correct command.

*Why the others are wrong: **B**, 750 = owner rwx (7), group r-x (5), others none (0). The group has read and execute but not write, they cannot create, edit, or delete files in the directory. **C**, 700 = owner rwx, group none, others none. The R&D group has no access at all, which contradicts the policy requirement. **D**, 755 = owner rwx, group r-x, others r-x. Others gain read and execute access to the directory, violating the "no access for others" requirement.*

14. In the Vitahealth scenario, the /RandD/Formula directory must allow the head researcher (owner) full access, the R&D team (group) read and execute access only, and all other users no access. Which numeric chmod value correctly implements this policy?

○ A. chmod 754 /RandD/Formula

○ B. chmod 740 /RandD/Formula

● C. chmod 750 /RandD/Formula

○ D. chmod 700 /RandD/Formula

Correct answer: C

Why: Owner = rwx = 7, group = r-x = 5 (read=4, execute=1, no write), others = --- = 0. Combined: 750. Execute permission on a directory is necessary for users to traverse into it; without it, even read permission would not allow listing the directory's contents.

*Why the others are wrong: **A**, 754 = owner rwx (7), group r-x (5), others r-- (4). Others gain read access, violating the no-access-for-others requirement. **B**, 740 = owner rwx (7), group r-- (4), others none. The R&D team can read but not execute, they cannot enter or traverse the Formula directory at all. **D**, 700 = owner only (rwx). The entire R&D group has no access, which contradicts the policy that grants them read and execute rights.*

15. A security analyst is implementing RBAC for a web application. Users assigned the "Auditor" role must be able to read audit log files but not modify or execute them. The audit logs are owned by root and associated with the "rnd" group. Which chmod value, applied to the audit log file, best enforces the Auditor group's read-only requirement if Auditors are assigned their own "auditor" group?

- **● A. chmod 640 audit.log**
- ○ B. chmod 770 audit.log
- ○ C. chmod 644 audit.log
- ○ D. chmod 600 audit.log

Correct answer: A

Why: 640 = owner rw (6), group r (4), others none (0). If the auditor group is set as the file's group, group members get read-only access with no write or execute. Others (non-auditors, non-owners) have no access. This precisely enforces the read-only Auditor requirement without leaking access to all users.

*Why the others are wrong: **B**, 770 gives the group read, write, and execute, Auditors would be able to modify or delete audit logs, undermining audit integrity. **C**, 644 gives group read access (correct), but also gives others read access, any user on the system could read potentially sensitive audit logs. **D**, 600 restricts access to the owner only, the Auditor group would have no access to the logs at all, making the role non-functional.*

16. A security auditor examines the Vitahealth server and finds the following permissions:
/RandD, chmod 755
/RandD/Research, chmod 770
/RandD/Formula, chmod 750

Vitahealth policy specifies: (1) R&D team has full rwx access to /RandD; other users may read and access it. (2) Only R&D members have any access to /RandD/Research. (3) Only the head researcher has rwx on /RandD/Formula; R&D team has r-x; all others have no access.

Which directory's permissions violate the policy, and why?

- ○ A. /RandD/Formula only, chmod 750 grants the R&D group too many permissions beyond what policy allows.
- ○ B. /RandD/Research only, chmod 770 incorrectly allows others to access and write to the directory.
- **● C. /RandD only, the R&D group is assigned r-x (5) but policy requires full rwx (7) for group; correct value is 775.**
- ○ D. All three directories are correctly configured per policy.

Correct answer: C

Why: chmod 755 = owner rwx (7), group r-x (5), others r-x (5). Policy (1) requires the R&D group to have full access (rwx = 7), but the group currently has only r-x (5), no write permission. The correct value is 775. /RandD/Research at 770 is correctly configured (group full, others none). /RandD/Formula at 750 is correctly configured (owner rwx, group r-x, others none), matching policy (3) exactly.

*Why the others are wrong: **A**, chmod 750 = owner rwx (7), group r-x (5), others none (0). This is exactly what policy (3) specifies, R&D team has read and execute, no write. There is no excess permission. **B**, chmod 770 = owner rwx (7), group rwx (7), others none (0). Others have no access. This is compliant with policy (2). There is no violation here. **D**, All three are not compliant, /RandD has a group permission of 5 (r-x) when it should be 7 (rwx) per policy.*

17. A junior administrator secures a sensitive application configuration file with the command: chmod 646 config.conf. A senior security engineer immediately flags this as a critical misconfiguration. Which specific problem does the senior engineer identify?

○ A. The owner cannot read the configuration file.

○ B. The group has write access, allowing group members to alter the configuration.

○ C. The execute bit is set for the owner, allowing arbitrary code execution from the config file.

● D. Others have read and write access, meaning any user on the system can read and modify the file.

Correct answer: D

Why: chmod 646 breaks down as: owner = 6 (rw-), group = 4 (r--), others = 6 (rw-). The "others" segment, covering all users on the system who are neither the owner nor in the assigned group, has read AND write permissions. Any local user can read the configuration (potentially exposing credentials, API keys, or system parameters) and overwrite it (potentially causing application failure or introducing malicious configuration). This is a severe least-privilege violation.

*Why the others are wrong: **A**, Owner has 6 (rw-), both read and write. There is no issue with the owner's access. **B**, Group has 4 (r--), read only, no write. Group members cannot modify the file. This is not the problem the engineer identified. **C**, In octal notation, 6 = 110 in binary = rw- (no execute bit). 4 = 100 = r-- (no execute). No execute bits are set anywhere in 646.*

18. Vitahealth Solutions is transitioning from DAC to RBAC on its R&D Linux server. Three roles are defined: Head Researcher, R&D Member, and Auditor. Auditors must be able to read all R&D directories for compliance reviews but must not have write access. Existing R&D member permissions must remain unchanged. Which implementation approach correctly realizes this RBAC structure on Linux?

○ A. Create an "auditor" Linux group; use chmod o+r on /RandD and all subdirectories to grant global read access to everyone including auditors.

● B. Create an "auditor" Linux group; use chmod and POSIX ACLs (setfacl) to grant the auditor group read-only access to each R&D directory without modifying existing rnd group permissions.

○ C. Add all auditor users directly to the existing "rnd" group so they inherit current R&D permissions; restrict them further only at the application layer.

○ D. Temporarily set all R&D directories to chmod 777 before each audit and revert them manually afterward.

Correct answer: B

Why: RBAC on Linux requires mapping each role to a distinct group. Because standard Unix permissions only support one group per file, adding a second group (auditors) with different permissions requires POSIX ACLs via setfacl. This allows fine-grained, per-group permission entries alongside the existing rnd group entry, auditors get read-only (r-x on directories) while rnd members retain their current permissions unmodified. This is the correct, least-privilege implementation that does not disturb existing access.

*Why the others are wrong: **A**, chmod o+r grants read access to all users on the system (the "others" class), not just auditors. This eliminates the role distinction entirely and violates least privilege. **C**, Adding auditors to the rnd group grants them all R&D member permissions, including write access, which violates the read-only requirement. Application-layer restrictions alone are insufficient; OS-level enforcement is necessary. **D**, Setting chmod 777 exposes all directories to all system users, not just auditors, and relies on error-prone manual reversal. A forgotten revert leaves all R&D data fully exposed, an unacceptable operational risk.*